Aran Learn 7: Data-Protection Law Basics

For: everyone. **Time:** about 4 hours. **Before this:** the README; Learn 3 section 6 helps for the erasure parts.

Laws are the reason banks will pay for Aran. This doc explains, in plain words and with worked scenarios, what Indian privacy and banking rules require and which Aran mechanism answers each one. It is a study guide, not legal advice: when you quote a rule in a presentation, open the source and quote the exact clause.

1. Why a technical team needs the law

Judges and bank officers will ask "which rule does this help with?" before "how does it work?". Every Aran feature should map to a duty that carries a penalty, because that is what turns a nice idea into a budget line. Three habits help:

1. Name the law, the section and what it requires.
2. Say exactly which part Aran helps with, and which part it does not (for example, Aran does not handle consent collection).
3. Say what still needs a lawyer's confirmation.

2. The DPDP Act 2023 and Rules 2025

2.1 What it covers

The Digital Personal Data Protection Act is India's main privacy law. It covers **digital personal data**: any data about an identifiable person that is in digital form, or collected on paper and later digitised. Aadhaar numbers, PAN, card numbers, mobile numbers, names with addresses and even a customer ID that the bank can link to a person are all personal data. It applies to processing in India, and to processing outside India when it is connected to offering goods or services to people in India.

2.2 The people in the law

Term	Plain meaning	In a bank
Data Principal	The person the data is about (for a child, the parent or guardian too)	The customer
Data Fiduciary	Whoever decides why and how data is processed	The bank
Data Processor	Whoever processes data on the fiduciary's behalf	Cloud providers, call centres, card-printing vendors, an analytics firm
Significant Data Fiduciary (SDF)	A fiduciary the government names for extra duties, based on volume and sensitivity of data and risk	Large banks are likely candidates
Consent Manager	A registered platform through which people give, manage and withdraw consent	A consent app linked to the bank
Data Protection Board of India	The regulator that hears complaints, investigates breaches and imposes penalties	Receives breach reports

Key point: the fiduciary stays responsible for what its processors do. If a bank's call-centre vendor leaks Aadhaar numbers, the bank answers to the Board. That is why Aran's per-destination tokens (Mechanism 3) matter: they show which processor leaked.

2.3 When a bank may process personal data

There are two lawful grounds.

Consent (section 6). It must be free, specific, informed, unconditional and unambiguous, given by a clear affirmative action, and limited to the data needed for the stated purpose. It can be withdrawn as easily as it was given. Before asking, the fiduciary gives a **notice (section 5)** saying what data is collected, for what purpose, and how to exercise rights and complain.

Certain legitimate uses (section 7). Processing without consent is allowed in listed cases, for example where the person voluntarily gave data for a specified purpose and did not object, or to comply with a law or a court order, or in a medical emergency.

Worked example. A customer opens a savings account. The bank processes their Aadhaar for KYC because the KYC rules require it: that is a legal obligation. The bank then wants to use their mobile number for loan offers: that needs separate consent, and if the customer later withdraws it, marketing must stop. Aran's purpose-bound keys (Mechanism 5) mirror exactly this split: the KYC key and the marketing key are different keys with different lifetimes.

2.4 Duties of a Data Fiduciary (section 8) that Aran supports

Duty	What it says	How Aran helps
Reasonable security safeguards, s. 8(5)	Protect personal data, including data with processors, to prevent a breach. The Rules name measures such as encryption, obfuscation or masking, use of virtual tokens, access control and logging	Aran's tokens and masks are those measures; the leakage ledger proves masks are strong enough (M1, M4)
Breach intimation, s. 8(6)	Tell the Board and each affected Data Principal about a personal data breach. The Rules ask for intimation without delay and a detailed report to the Board within 72 hours	Leak attribution answers what leaked, from which destination and since when (M3)
Erasure, s. 8(7)	Erase data when consent is withdrawn or the purpose is no longer served, unless another law requires keeping it, and make processors erase too	Purpose-bound crypto-shredding erases every copy, including at processors, with a verifiable receipt (M5)
Log retention (Rules)	Keep logs of processing for at least one year	Logs hold tokens, not raw identifiers, so keeping them is safe (M1)
Grievance redressal, s. 8(10)	Publish a contact and answer complaints	Erasure receipts let the bank show, not just say, that it erased

2.5 Rights of the Data Principal

Right	Section	What the customer can ask
Access	11	A summary of their data being processed and who it was shared with
Correction and erasure	12	Fix wrong data; erase data no longer needed
Grievance redressal	13	Complain to the bank first, then to the Board
Nomination	14	Name someone to act for them on death or incapacity

The right of access has a direct link to Aran: "who was my data shared with?" is hard for a bank to answer from scattered logs. Aran's flow graph records every destination that received each customer's tokens.

People also have **duties (section 15)**, such as not filing false complaints; breaking them can cost up to Rs 10,000.

2.6 Extra rules worth knowing

- **Children (section 9):** anyone under 18. Processing needs verifiable consent of a parent or guardian, and tracking, behavioural monitoring and targeted advertising at children are not allowed. Minor savings accounts fall here.
- **Significant Data Fiduciaries (section 10):** must appoint a Data Protection Officer based in India, an independent data auditor, and carry out periodic data protection impact assessments and audits.
- **Transfers outside India (section 16):** allowed except to countries the government restricts, but stricter sector rules still apply. For banks, RBI's payment-data rule is stricter (section 3).

2.7 Penalties (Schedule to the Act)

Failure	Maximum penalty
Failing to take reasonable security safeguards to prevent a breach	Rs 250 crore
Failing to notify the Board or affected people of a breach	Rs 200 crore
Breaking the extra duties for children	Rs 200 crore
Breaking the extra duties of a Significant Data Fiduciary	Rs 150 crore
Any other breach of the Act or Rules	Rs 50 crore
A Data Principal breaking their duties	Rs 10,000

The Board decides the amount for each case, considering how serious and how long the breach was, the harm, and what the fiduciary did to reduce it. A bank that can show strong safeguards and fast, accurate reporting is in a much better position.

2.8 Key dates

Date	Event
11 August 2023	Act receives assent
13 November 2025	DPDP Rules 2025 notified; Board provisions start
13 November 2026	Consent manager provisions apply
13 May 2027	Core duties of Data Fiduciaries apply

3. Banking and sector rules

Banks follow sector rules on top of DPDP. Each one below maps to an Aran mechanism (M1 to M5 in the research doc).

3.1 CERT-In Directions (28 April 2022)

Issued under the IT Act. Two parts matter for Aran:

- **Report listed cyber incidents to CERT-In within 6 hours** of noticing them. Data breaches and data leaks are on the list.
- **Keep ICT system logs for a rolling 180 days, stored in India,** and provide them to CERT-In when asked.

Aran's answer: logs contain tokens, not raw identifiers, so keeping them for 180 days does not create a second leak risk; attribution gives the facts needed for the 6-hour report.

3.2 UIDAI Aadhaar Data Vault

UIDAI has required since 2017 that entities storing Aadhaar numbers keep them only in a secure **Aadhaar Data Vault**: encrypted (AES-256 is named), with keys in an HSM, on a separate access-controlled network. Every other business system uses a **reference key** in place of the Aadhaar number. UIDAI Circular 8 of 2025 builds on this. Aran's vault-mode tokens are such reference keys, and the checksum-complement form (M1) proves to any scanner that they are not Aadhaar numbers.

3.3 RBI rules

Rule	What it says	Aran's answer
Storage of payment system data (April 2018)	All data about payment systems operated in India must be stored only in India	Aran runs inside the bank's own infrastructure; token vaults stay in India
Card-on-file tokenisation (2021 onward)	Merchants and payment aggregators may not store full card numbers; they use network tokens	Aran's card tokens fail Luhn (M1), so a stored card-shaped value is provably not a real card; per-destination tokens (M3)
KYC Master Direction, with PMLA rules	Keep customer identification records and transaction records for at least five years after the relationship ends or the transaction	Time-locked KYC keys shred automatically when the retention period ends (M5)

3.4 PCI DSS (industry standard for card data)

Not a law, but card networks require it. Stored card numbers must be unreadable (by tokens, truncation, strong encryption or one-way hashes). When displayed, the commonly accepted maximum is the first 6 and last 4 digits; for 16-digit cards with 8-digit IINs, PCI SSC allows first 8 and last 4. Learn 4 shows that first 8 and last 4 leaves only 1,000 possibilities, about 10 bits. Aran's leakage ledger (M4) measures this and blocks combinations of views that leave too little.

4. Worked scenarios

4.1 A leak is found

A security researcher emails the bank a link to a paste site with 500 Aadhaar-shaped numbers.

Time	What happens	Rule
T + 0	Aran's scanner checks the 500 numbers. 498 fail Verhoeff, so they are Aran tokens, not raw Aadhaar; 2 pass	M1
T + 10 minutes	The 498 tokens are all found in the token table of one destination: the call-centre vendor's export	M3
T + 1 hour	The 2 valid numbers are checked against the own-customer registry; neither belongs to a customer, so they are coincidences	Learn 4
Before T + 6 hours	Incident reported to CERT-In with the source system and scope	CERT-In Directions
Without delay	Board and affected customers told what happened and what to do	DPDP s. 8(6), Rules
Within 72 hours	Detailed report to the Board: cause, scope, the vendor involved, steps taken	DPDP Rules

Because tokens leaked and not Aadhaar numbers, the harm is much smaller. The bank can also show the Board that it had "reasonable security safeguards" in place, which affects the penalty.

4.2 Erasure that conflicts with retention

A customer closes their account and asks the bank to erase all their data.

1. The marketing and servicing purposes are over. Aran destroys keys cust-101/marketing and cust-101/servicing now, writes both destructions into the Merkle log and sends the customer a signed receipt.
2. The KYC records must be kept for five years after the relationship ends. The cust-101/kyc key is time-locked and shreds automatically on that date; the receipt says so.
3. Tokens for this customer remain in 180-day logs, but after shredding they link to nothing.

The customer gets a clear, verifiable answer instead of "your request has been noted".

4.3 A processor wants raw data

An analytics vendor asks for raw card numbers to "improve fraud models". Under DPDP the bank stays responsible for the vendor, PCI DSS forbids unnecessary storage, and the vendor only needs to join records, not read numbers. Aran gives the vendor its own per-destination tokens: joins still work, and a leak from the vendor names the vendor.

5. Is a token still personal data?

This is the question lawyers will ask first.

- **While the bank can reverse it** (through the vault or the FF1 key), a token is still personal data, because the bank can identify the person. DPDP duties still apply to it, but the risk is far lower, which is what "reasonable safeguards" is about.
- **For a third party who finds it**, a vault token reveals nothing; an FF1 token reveals nothing without the key.
- **After key shredding**, Aran argues the token becomes anonymous: there is no key and no table that links it to anyone, so no one, including the bank, can identify the person. If that view is accepted, crypto-shredding counts as erasure. This still needs legal confirmation, and the research doc says so.

6. Questions judges will ask, with model answers

Prepare your own two-sentence version of each.

- **Who is the Data Fiduciary and who is the Data Processor in your demo?** The bank is the fiduciary; the CRM vendor, the call centre and the analytics firm are processors. Each processor gets its own tokens, so the bank can prove which one leaked.
- **How does Aran help meet the 72-hour breach report?** It tells within minutes whether a leaked dump holds real identifiers or tokens, and which destination the tokens came from. That is most of what the report needs.
- **Logs must be kept for 180 days (CERT-In) and at least a year (DPDP Rules). How can you also honour erasure?** The logs hold tokens. Erasure destroys the customer's key, so the tokens stay in the logs but no longer link to anyone.
- **Is a token still personal data?** Yes while the bank can reverse it. After shredding, Aran argues it is anonymous; we have marked that as needing legal confirmation.

- **Why not just mask everything?** Some systems must join or reverse values, and some common masks leak more than they look: first 8 and last 4 of a card leaves only 1,000 possibilities.
- **What if an insider who is allowed to see raw data leaks it?** Aran limits who sees raw data at all, logs every detokenisation, and the immune layer flags unusual volumes. It cannot stop someone photographing a screen, and we say so.
- **Does Aran handle consent?** No. Consent collection belongs to the bank's consent systems or a consent manager. Aran enforces purpose after consent: each purpose has its own key.

7. Practice

- [ ] **P1.** Read sections 5, 6, 8 and 12 of the DPDP Act from the official text and write one line on each in your own words.
- [ ] **P2.** For each Aran mechanism M1 to M5, name one rule it helps with and one it does not.
- [ ] **P3.** Rewrite scenario 4.1 for a leak of raw card numbers instead of tokens. Which steps change?
- [ ] **P4.** Practise the judge questions in pairs: one asks, the other answers in under 30 seconds.
- [ ] **P5.** Find the exact wording on breach intimation in the DPDP Rules 2025 and check our 72-hour summary against it.

8. Sources

- DPDP Act 2023, the Schedule of penalties
- DPDP Rules 2025 summary, Khaitan & Co (15 Nov 2025)
- CERT-In Directions, 28 April 2022
- UIDAI Aadhaar Data Vault, Khaitan & Co (10 Dec 2025)
- PCI SSC on 8-digit BINs
- The official Act text is on the Ministry of Electronics and IT website (meity.gov.in); RBI circulars and master directions are at rbi.org.in.